

XOLVON API

Dokumentasi Integrasi REST API

Dokumentasi ini dibuat dari kontrak endpoint aktif repository dan collection Postman Xolvon. Isinya fokus pada integrasi, pengujian, autentikasi, payload, keamanan, dan alur bisnis yang benar-benar tersedia.

Scope	Backend API Xolvon V1
Global prefix	/api
Auth	Bearer JWT; role user dan admin
Pagination	page 1-based; limit default 20, maksimum 100
Postman requests	tidak tersedia

1. Konvensi API

Semua route backend menggunakan global prefix **/api**. Format utama adalah JSON over HTTP. Route private menggunakan Authorization Bearer JWT. Validasi global memakai whitelist, forbidNonWhitelisted, dan transform.

- Endpoint public hanya mengembalikan konten published dan field aman.
- Endpoint admin memerlukan JWT dengan role admin.
- Pagination memakai page mulai 1 dan limit maksimum 100.
- Mutation sensitif publish, verify, activate, revoke, dan cancel dicatat dalam audit internal.
- Tidak ada endpoint publik untuk membuat admin, mengubah role, atau membaca audit log.

2. Auth Flow

- POST /auth/register membuat user biasa. Field role tidak diterima.
- POST /auth/login mengembalikan accessToken, refreshToken, dan user.
- Gunakan accessToken pada header Authorization untuk route private.
- POST /auth/refresh menerbitkan access token baru.
- POST /auth/logout mencabut refresh session.
- AuthGuard dan RolesGuard memeriksa token serta role di server.

Payload login

```
{  "email": "user@example.com",  "password": "Password123!"}
```

3. Endpoint Aktif

Endpoint di bawah diparsing dari docs/api-contract.md. Total route terdeteksi: 73.

Auth

Method	Path	Auth / Role	Deskripsi
POST	/api/auth/register	Public	Registrasi user baru; role tidak pernah diterima dari input (DL-005)
Method	Path	Auth / Role	Deskripsi
POST	/api/auth/login	Public	Login; mencatat IP + user agent ke sesi; rate limit menyusul (DL-012)
Method	Path	Auth / Role	Deskripsi
POST	/api/auth/refresh	Public	Terbit access token baru via refresh token
Method	Path	Auth / Role	Deskripsi
POST	/api/auth/logout	Public	Revoke sesi refresh token
Method	Path	Auth / Role	Deskripsi
GET	/api/auth/me	Bearer JWT	Profil user dari payload JWT sesi
Method	Path	Auth / Role	Deskripsi
GET	/api/auth/admin	Bearer JWT	Cek akses admin

Orders

Method	Path	Auth / Role	Deskripsi
POST	/api/orders	Bearer JWT	Checkout; total dihitung server-side; status awal pending (DL-002)

Method	Path	Auth / Role	Deskripsi
POST	/api/orders/:id/payment-proof	Bearer JWT	Submit object key bukti bayar; cek kepemilikan anti-IDOR
Method	Path	Auth / Role	Deskripsi
PATCH	/api/orders/:id/verify	Bearer JWT	Verifikasi pembayaran → paid; setelah rekonsiliasi T3 hanya dari pending (DL-002) + audit
Method	Path	Auth / Role	Deskripsi
POST	/api/orders/:id/activate	Bearer JWT	Aktivasi enrollment dari order paid; idempoten via upsert

Enrollments

Method	Path	Auth / Role	Deskripsi
GET	/api/enrollments/me	Bearer JWT	Daftar enrollment milik sesi (anti-IDOR, dari user.sub)
Method	Path	Auth / Role	Deskripsi
PATCH	/api/enrollments/:id/revoke	Bearer JWT	Revoke enrollment → revoked + audit (plan T15)

App

Method	Path	Auth / Role	Deskripsi
GET	/api	Public	Health check / hello

Search

Method	Path	Auth / Role	Deskripsi
GET	/api/search	Public	Pencarian lintas course, project, dan marketplace; hanya published; FTS5; ?q= opsional, ?type=course\

Home

Method	Path	Auth / Role	Deskripsi
GET	/api/home	Public	Agregasi homepage published-only (featured courses, projects, marketplace, collective) tanpa N+1; throttled group catalog

Courses

Method	Path	Auth / Role	Deskripsi
GET	/api/courses	Public	Katalog published-only, ?q= contains pada title (LIKE, wildcard di-escape), ?sort=latest\
Method	Path	Auth / Role	Deskripsi
GET	/api/courses/:slug	Public	Detail published-only (draft → 404) + lessons terurut order_index ASC — ringkasan aman tanpa content/video_object_key/signed URL (SCHEMA.md §17)
Method	Path	Auth / Role	Deskripsi
POST	/api/courses	Bearer JWT	Buat course (status awal draft, UUID server-generated) + audit create; slug unik
Method	Path	Auth / Role	Deskripsi
PATCH	/api/courses/:id	Bearer JWT	Update parsial + audit update; slug baru dicek unik
Method	Path	Auth / Role	Deskripsi
POST	/api/courses/:id/publish	Bearer JWT	Transisi ketat draft → published, gate field wajib (description, price) + audit publish
Method	Path	Auth / Role	Deskripsi
POST	/api/courses/:id/unpublish	Bearer JWT	Transisi ketat published → draft + audit unpublish

Method	Path	Auth / Role	Deskripsi
GET	/api/courses/:slug/lessons	Public	Daftar lesson published milik course published (src/lessons/course-lessons.controller.ts),urut order_index ASC; ringkasan aman tanpa content/video_object_key

Collective

Method	Path	Auth / Role	Deskripsi
GET	/api/collective	Public	Member published-only, ?q= (LIKE name/role/skills), pagination DL-011, urut display_order ASC lalu created_at DESC
Method	Path	Auth / Role	Deskripsi
GET	/api/collective/:slug	Public	Detail member + relatedProjects via project_members (published); TIDAK pernah memuat email/telepon (SCHEMA.md §57)
Method	Path	Auth / Role	Deskripsi
POST	/api/collective	Bearer JWT	Buat member (status awal draft) + audit create
Method	Path	Auth / Role	Deskripsi
PATCH	/api/collective/:id	Bearer JWT	Ubah member + audit update
Method	Path	Auth / Role	Deskripsi
POST	/api/collective/:id/publish	Bearer JWT	Set status published + audit publish
Method	Path	Auth / Role	Deskripsi
POST	/api/collective/:id/unpublish	Bearer JWT	Set status draft + audit unpublish

Projects

Method	Path	Auth / Role	Deskripsi
GET	/api/projects	Public	Portfolio published-only, ?q= contains pada title/summary, ?sort=latest
Method	Path	Auth / Role	Deskripsi
GET	/api/projects/:slug	Public	Detail published-only (draft → 404, sama seperti slug tak dikenal); urutan cerita Problem→Solution→Tech Stack→Result→Media (sort_order ASC, video dan object key dieksklusi) → members[].role dari JOIN collective_members (SCHEMA.md §47-48)
Method	Path	Auth / Role	Deskripsi
POST	/api/projects	Bearer JWT	Buat project (status awal draft) + audit create; slug unik; type string terkontrol (bukan enum final)
Method	Path	Auth / Role	Deskripsi
PATCH	/api/projects/:id	Bearer JWT	Update parsial + audit update; slug baru dicek unik
Method	Path	Auth / Role	Deskripsi
POST	/api/projects/:id/publish	Bearer JWT	Transisi ketat draft → published, gate field wajib (title, slug, type, summary, problem, solution) + audit publish
Method	Path	Auth / Role	Deskripsi
POST	/api/projects/:id/unpublish	Bearer JWT	Transisi ketat published → draft + audit unpublish
Method	Path	Auth / Role	Deskripsi
POST	/api/projects/:id/media	Bearer JWT	Attach media (objectKey, mediaType string terkontrol — enum final open decision DL-014, sortOrder) + audit create
Method	Path	Auth / Role	Deskripsi
DELETE	/api/projects/:id/media/:mediaId	Bearer JWT	Detach media ter-scope ke project (lintas project → 404) + audit delete

Method	Path	Auth / Role	Deskripsi
POST	/api/projects/:id/members	Bearer JWT	Assign collective member dengan role eksplisit (upsert ON CONFLICT(project_id, member_id)); role string terkontrol (bukan enum final) + audit create
Method	Path	Auth / Role	Deskripsi
DELETE	/api/projects/:id/members/:memberId	Bearer JWT	Remove assignment member ter-scope ke project + audit delete

Admin

Method	Path	Auth / Role	Deskripsi
GET	/api/admin/users	Bearer JWT	Paginated user list.
Method	Path	Auth / Role	Deskripsi
GET	/api/admin/users/:id	Bearer JWT	User detail.
Method	Path	Auth / Role	Deskripsi
GET	/api/admin/orders	Bearer JWT	Paginated order list.
Method	Path	Auth / Role	Deskripsi
GET	/api/admin/overview	Bearer JWT	User/order/enrollment summary.

Learning, media, and order operations

Method	Path	Auth / Role	Deskripsi
POST	/api/courses/:courseId/lessons	admin	
Method	Path	Auth / Role	Deskripsi
PATCH	/api/lessons/:id	admin	
Method	Path	Auth / Role	Deskripsi
DELETE	/api/lessons/:id	admin	
Method	Path	Auth / Role	Deskripsi
PATCH	/api/lessons/:id/reorder	admin	
Method	Path	Auth / Role	Deskripsi
POST	/api/lessons/:id/publish	admin	
Method	Path	Auth / Role	Deskripsi
POST	/api/lessons/:id/unpublish	admin	
Method	Path	Auth / Role	Deskripsi
POST	/api/lessons/:lessonId/resources	admin	
Method	Path	Auth / Role	Deskripsi
DELETE	/api/resources/:id	admin	
Method	Path	Auth / Role	Deskripsi
GET	/api/lessons/:id/video-url	user	
Method	Path	Auth / Role	Deskripsi
POST	/api/progress	user	
Method	Path	Auth / Role	Deskripsi
GET	/api/progress	user	
Method	Path	Auth / Role	Deskripsi
PATCH	/api/enrollments/:id/revoke	admin	
Method	Path	Auth / Role	Deskripsi
POST	/api/orders/:id/cancel	admin	

Method	Path	Auth / Role	Deskripsi
POST	/api/admin/media/upload-url	admin	
Method	Path	Auth / Role	Deskripsi
POST	/api/admin/media/confirm	admin	
Method	Path	Auth / Role	Deskripsi
POST	/api/admin/media/read-url	admin	

Marketplace & Marketplace Media

Method	Path	Auth / Role	Deskripsi
GET	/api/marketplace	Public	Listing published-only, ?q= (LIKE title/description, wildcard di-escape), ?sort=latest\
Method	Path	Auth / Role	Deskripsi
GET	/api/marketplace/:slug	Public	Detail published-only (draft → 404); mediaurut sort_order ASC; capabilities diparse dari comma-separated TEXT
Method	Path	Auth / Role	Deskripsi
POST	/api/marketplace	Bearer JWT	Buat listing (status awal draft) + audit create; externalUrl wajib https valid
Method	Path	Auth / Role	Deskripsi
PATCH	/api/marketplace/:id	Bearer JWT	Update parsial + audit update; slug baru dicek unik; externalUrl divalidasi ulang
Method	Path	Auth / Role	Deskripsi
POST	/api/marketplace/:id/publish	Bearer JWT	Transisi ketat draft → published + audit publish
Method	Path	Auth / Role	Deskripsi
POST	/api/marketplace/:id/unpublish	Bearer JWT	Transisi ketat published → draft + audit unpublish
Method	Path	Auth / Role	Deskripsi
POST	/api/marketplace/:id/media	Bearer JWT	Attach media (objectKey R2, mediaType image\
Method	Path	Auth / Role	Deskripsi
DELETE	/api/marketplace/:id/media/:mediaId	Bearer JWT	Detach media ter-scope ke item (lintas item → 404) + audit delete

Admin — aktif

Method	Path	Auth / Role	Deskripsi
GET	/api/admin/users	Bearer JWT	
Method	Path	Auth / Role	Deskripsi
GET	/api/admin/orders	Bearer JWT	
Method	Path	Auth / Role	Deskripsi
GET	/api/admin/overview	Bearer JWT	

Media (R2) — aktif

Method	Path	Auth / Role	Deskripsi
POST	/api/admin/media/upload-url	Bearer JWT	
Method	Path	Auth / Role	Deskripsi
POST	/api/admin/media/confirm	Bearer JWT	

Lessons video & Progress — aktif

Method	Path	Auth / Role	Deskripsi
GET	/api/lessons/:id/video-url	Bearer JWT	
Method	Path	Auth / Role	Deskripsi
POST	/api/progress	Bearer JWT	

4. Payload Integrasi

Payload create tidak menerima status. Resource dibuat sebagai draft lalu berpindah status melalui endpoint publish atau unpublish.

Register

```
{
  "name": "Xolvon User",
  "email": "user@example.com",
  "phone": "+6281234567890",
  "password": "Password123!"
}
```

Create course

```
{
  "title": "Course Contoh",
  "slug": "course-contoh",
  "description": "Deskripsi course.",
  "price": 150000,
  "thumbnailUrl": "https://example.com/thumb.webp"
}
```

Checkout order

```
{
  "courseIds": ["00000000-0000-4000-8000-000000000000"],
  "notes": "Pembayaran via transfer."
}
```

Update progress

```
{
  "lessonId": "00000000-0000-4000-8000-000000000000",
  "completed": true
}
```

5. Validasi dan Query

Area	Aturan	Hasil salah
UUID	ID internal harus UUID v4	400 Bad Request
Slug	lowercase kebab-case dan unik	400 atau 409
Pagination	page 1-based; limit maksimal 100	400 Bad Request
Media	prefix, MIME, dan ukuran memakai allowlist	400 Bad Request
Marketplace URL	externalUrl harus HTTPS valid	400 Bad Request

- 200 request berhasil.
- 201 resource dibuat.
- 400 DTO, format, atau state transition salah.
- 401 token tidak ada atau tidak valid.
- 403 role tidak cukup.
- 404 resource tidak ditemukan atau tidak terlihat.
- 409 konflik slug atau state.
- 429 rate limit tercapai.
- 500 kegagalan server; jangan tampilkan stack trace ke client.

6. Alur Bisnis Utama

Checkout sampai enrollment

- User membaca course published melalui GET /courses.

- User membuat POST /orders; total dihitung server-side.
- User mengirim POST /orders/:id/payment-proof.
- Admin menjalankan PATCH /orders/:id/verify untuk pending → paid.
- Admin menjalankan POST /orders/:id/activate untuk membuat enrollment idempoten.
- User membaca GET /enrollments/me.
- User meminta signed video URL dan menyimpan progress lesson.

Publikasi konten

- Admin membuat resource draft.
- Admin mengubah data melalui PATCH.
- Admin menjalankan endpoint publish.
- Endpoint publik hanya membaca published.
- Unpublish mengembalikan resource ke draft tanpa menghapus data.

7. Security Contract

- Ownership order, progress, enrollment, dan video diturunkan dari JWT subject untuk mencegah IDOR.
- Response tidak memuat password hash, refresh token, object key privat, kredensial R2, atau stack trace.
- Media privat memakai signed URL berdurasi terbatas.
- Login dan register dibatasi 5 request per menit per IP.
- Helmet security headers dan explicit CORS origin whitelist aktif.
- Search memakai validasi query dan parameter binding.
- Jangan memasukkan token, password, API key, atau credential ke Postman collection maupun PDF.

8. Runbook QA Postman

- Set {{baseUrl}} ke `http://localhost:3000/api` atau environment target.
- Import `Xolvon-API.postman_collection.json`.
- Jalankan Health check.
- Login user untuk enrollment/progress; login admin untuk CRUD dan moderation.
- Simpan UUID hasil create ke collection variables.
- Uji happy path order → payment proof → verify → activate → enrollment → video URL → progress.
- Uji negative path: token kosong, role user ke route admin, UUID invalid, field ekstra, ID lintas user, draft pada endpoint public, dan repeated transition.
- Jangan menguji cancel, revoke, delete, atau upload ke production tanpa fixture dan persetujuan.

9. Referensi Source

- `docs/api-contract.md`
- `src/main.ts`
- `src/auth/auth.controller.ts`
- `src/orders/orders.controller.ts`
- `src/courses/courses.controller.ts`
- `src/projects/projects.controller.ts`
- `src/marketplace/marketplace.controller.ts`
- `Xolvon-API.postman_collection.json`

Dokumen ini dibuat dari keadaan repository saat generate. Jika controller atau DTO berubah, regenerate PDF agar kontrak tetap sinkron.